

Securing Sensitive Data in GenAI Development

Once a team moves from using commercial GenAI tools to building on top of them, agents, RAG pipelines, and MCP integrations open entirely new paths for sensitive data to leak. This session names seven risks unique to custom GenAI development, the real incidents behind five of them, and what to do about each.



Presenter: Linfei Gu, Proofpoint

- 01 Three ways teams build with GenAI
- 02 Seven risks unique to custom development
- 03 Frameworks to build against
- 04 Locking down integrations and training data
- 05 Risk, spotted in a live system
- 06 Where this leaves you

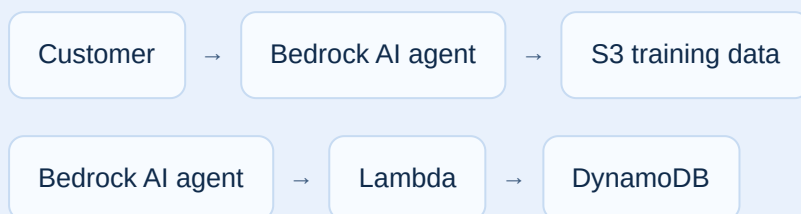
QUICK RECALL

Custom GenAI development opens three risk surfaces beyond commercial tools: RAG pipelines, agent/MCP integrations, and model fine-tuning. Each has its own named risks, its own dated incidents, and its own fix.

Three ways teams build with GenAI

Session 2 covered the pattern most organizations start with: employees reaching for a commercial GenAI tool as-is, sanctioned or not. Two further patterns show up as a program matures. The second augments a commercial app with an organization's own systems and data, M365 Copilot pulling from Confluence, ChatGPT wired into Google Workspace, Claude connected to GitHub, typically through an API, an MCP server, or a RAG pipeline. The third replaces the commercial app altogether: a custom GenAI application or agentic workflow built on a platform like AWS Bedrock or Azure AI Foundry, or on infrastructure built entirely in-house.

A representative version of that third pattern puts a customer-facing AI agent on Bedrock in front of an S3 bucket of training data, with a connected Lambda function writing to DynamoDB:



Three questions worth asking before shipping one of these: Can the agent be hijacked into taking actions it shouldn't? Could it expose PII while completing an otherwise legitimate task? Could sensitive data end up baked into a training set by accident?

Seven risks unique to custom development

Building or extending a GenAI app introduces risks that using a commercial tool as-is doesn't, and they tend to lead to the same handful of outcomes: unauthorized access to sensitive data, data exfiltration and security breaches, compliance violations, operational disruption, and severe financial loss. Seven distinct risks recur across RAG pipelines, agent and MCP integrations, and fine-tuning, and Proofpoint's own list leaves room for more beyond these seven. Polled live on which one worried them most, the room's answers spread across nearly the whole list, tool poisoning, data leakage, prompt injection and poisoning attacks all drew real votes, with almost nobody picking "not concerned."

☒ RAG pipelines ☒ Agents & MCP ☒ Fine-tuning

[Collapse all](#)

- **RAG data poisoning**

RAG

Attackers insert malicious data into a knowledge base to manipulate model behavior or trick the app into exfiltrating sensitive information. In August 2024, attackers poisoned a Microsoft 365 Copilot RAG pipeline through a prompt-injected email, then used it to trick users into wiring money to a fraudulent bank account.

- **Data inversion**

RAG

Vulnerabilities in a vector database can be exploited to invert embeddings and reconstruct the original data behind them. In June 2024, researchers reconstructed clinical notes with over 98% accuracy using nothing but the embeddings stored in a vector database.

- **Data leakage & oversharing**

RAG

GenAI apps and the external datastores behind them often lack the strict access control of the systems they're built on, giving users or agents unauthorized access to sensitive data. In January 2025, a customer's AI chatbot, asked to retrieve recent invoices, returned invoices belonging to unrelated customers.

- **Prompt injection**

AGENTS & MCP

Malicious instructions hidden inside a prompt manipulate an AI agent into performing unintended actions. In May 2025, a maliciously crafted public GitHub issue tricked an AI coding agent into exfiltrating sensitive data from private repositories.

- **Tool poisoning**

AGENTS & MCP

Malicious tool instructions trick an AI agent into executing unauthorized commands or exfiltrating sensitive data. In April 2025, a malicious MCP server used hidden instructions to exfiltrate credentials from a user's MCP configuration file through the Cursor editor.

- **Training data poisoning**

FINE-TUNING

Manipulating the data used for pre-training or fine-tuning introduces vulnerabilities, backdoors, or biases into the resulting model without needing to compromise the model itself afterward.

- **Memorization**

FINE-TUNING

Sensitive data from a training set can be memorized by the model and disclosed later during inference. In May 2023, researchers showed that malicious prompts could cause a model to diverge from normal generation and disclose memorized training data, including PII and source code.

Frameworks to build against

None of this needs to be worked out from first principles. A growing set of frameworks already covers secure GenAI and agentic AI development:

NIST

The AI Risk Management Framework, plus the newer AI 600-1 profile written specifically for generative AI.

ISO/IEC 42001:2023

A management-system standard for how an organization governs an AI program.

CSA

The AI Controls Matrix (AICM), a cloud-security-style control set for AI systems.

MITRE ATLAS

A catalog of real adversarial tactics and techniques used against AI systems.

OWASP GenAI Security Project

The LLM Top 10, a set of LLM and GenAI data security best practices, and a guide to agentic AI threats and mitigation.

Platform frameworks

Google's Secure AI Framework, Databricks AI Security Framework 2.0, and AWS's Generative AI Security Scoping Matrix, among others.

Locking down integrations and training data

The fixes split cleanly along the same two lines as the risks above: what a GenAI app connects to, and what it's trained on.

☒ Integrations ☐ Training data

[Collapse all](#)

Securing integrations

- Understand data exposure risk

INTEGRATION

Scan integrated data stores to discover and classify sensitive data, then evaluate and mitigate the exposure it creates: sanitize sensitive data out of RAG knowledge bases before it gets indexed, and evaluate the sensitivity of any resource or function an MCP server exposes.

- Protect sensitive data in agentic activities

INTEGRATION

Inspect the data flows between agents, systems, and data stores to prevent unauthorized access or sharing: monitor agent activity and enforce usage policies for sensitive data, and block or redact sensitive data before it reaches a human or another agent.

- Secure credentials

INTEGRATION

Secure the machine credentials that power these integrations, API keys, OAuth tokens, SSH keys, and service accounts, by following secrets-management practice such as avoiding hard-coded credentials, and by continuously scanning data stores for credentials left unprotected.

- Evaluate before integrating

INTEGRATION

Update or establish a vendor assessment process that thoroughly evaluates risk before integration: review what data third-party connectors and plugins actually use, and review MCP server providers for the security controls they have in place.

Securing training data

Fine-tuning a foundation model on organizational data carries its own risk profile: regulated data such as PII or PHI can violate privacy rules if it lands in a training set, confidential information like intellectual property or trade secrets can be memorized and later exposed by the model, and teams can spin up shadow AI training projects with no security oversight at all.

- **Sanitize before training**

TRAINING DATA

Discover, classify and sanitize sensitive data in a dataset before it's used to fine-tune a model.

- **Continuously monitor**

TRAINING DATA

Continuously scan connected training datasets to discover and classify any new sensitive data that lands in them.

- **Restrict access**

TRAINING DATA

Monitor and govern access to training datasets to prevent exfiltration or poisoning.

- **Trace data flows**

TRAINING DATA

Trace the data pipelines between AI models and training datasets to detect shadow AI: model training projects spun up without IT or security oversight.

- **Prevent misconfiguration**

TRAINING DATA

Detect and fix misconfigurations in how training data is stored.

Risk, spotted in a live system

Lucid, the customer-facing ticketing agent

Live demo · agentic activity

Lucid, a fictional customer AI agent, files support tickets on customers' behalf when it can't resolve an issue itself. In the demo, Lucid opened a high-priority ticket, "Finance Dashboard Totals Incorrect," after a customer's finance team flagged inconsistent quarterly revenue figures, and assigned it to the engineering team with itself listed as reporter. Before the ticket reached anyone, a data-loss-prevention layer automatically stripped the sensitive data Lucid had included and left a visible redaction marker in its place, a concrete instance of the "protect sensitive data in agentic activities" recommendation above: catching what an agent shares on someone's behalf, not only what a person types.

The S3 bucket nobody had flagged

Live demo · data store discovery

A second demo filtered a data security posture view down to data stores connected to AI services: AWS Bedrock, GCP Vertex AI, and Azure ML. One S3 bucket wired into Bedrock carried a risk score in the hundreds. It held classified sensitive data, Social Security numbers, payment card numbers, addresses, phone numbers, and its list of open risks included public accessibility, a disabled block-public-access setting, an IAM user without MFA, and no enforced TLS 1.2 for data in transit. Every one of those issues predates the AI integration; connecting an already-exposed bucket to Bedrock is what turns an old misconfiguration into active data exposure.

Where this leaves you

Custom development is where GenAI security stops being about trusting a vendor and starts being about your own architecture: what a RAG pipeline indexes, what an agent is allowed to call, what ends up in a training set. Five of the seven risks above have a dated, named incident attached, which makes the point plainly: none of this is theoretical. The fix is the same discipline this series has applied at every layer so far. Know what data you have, know what's connected to it, and watch what moves between them.

Notes from Proofpoint Cybersecurity Academy, AI Data Security Specialist, Session 3.
Compiled by Anmol Nisar, September 2026.